علوم الحاسب ونظم المعلومات
Info Sys & Comp Science

جامعة ٦ أكتوبر
October 6 University

CONFIDENTIAL

PENETRATION TESTING SECURITY ASSESSMENT REPORT

CLIENT	zero.webappsecurity
TARGET	http://zero.webappsecurity.com
REPORT REFERENCE	VC-1773355834233
ASSESSMENT DATE	March 13, 2026
VERSION	1.0
SECURITY POSTURE	Good

Generated by VulnCraft AI Security Assessment Platform
This document is classified as **CONFIDENTIAL**

TABLE OF CONTENTS

1 Document Information & Methodology

2 Executive Summary

3 Risk Overview & Severity Distribution

4 Detailed Security Findings

5 Risk Register

6 Strategic Recommendations

7 Security Program Improvements

8 Assessment Verdict

9 Disclaimer & Terms

1 Document Information & Methodology

1.1 Report Details

REPORT TYPE	Evidence-Based Penetration Testing & Security Assessment
REPORT REFERENCE	**VC-1773355834233**
TARGET URL	`http://zero.webappsecurity.com`
ASSESSMENT DATE	March 13, 2026
CLASSIFICATION	CONFIDENTIAL
VERSION	1.0
ASSESSMENT TYPE	Automated Black-Box Testing with AI-Powered Analysis
GENERATED BY	VulnCraft AI Security Platform

1.2 Assessment Methodology

This security assessment was conducted using a multi-layered automated testing approach aligned with industry-standard methodologies:

FRAMEWORK	Description
OWASP TESTING GUIDE V4.2	Application security testing covering the OWASP Top 10 2021 categories including injection, broken access control, and security misconfiguration
PTES	Penetration Testing Execution Standard — structured approach from intelligence gathering through reporting
NIST SP 800-115	Technical Guide to Information Security Testing and Assessment — systematic methodology for security evaluation
CWE/CVE MAPPING	All findings mapped to Common Weakness Enumeration (CWE) identifiers and relevant CVE entries where applicable

1.3 Scope & Limitations

TEST TYPE	External Black-Box — no source code access, no authentication credentials
SCOPE	Target URL and directly-linked resources. Subdomains and third-party services excluded unless explicitly referenced in findings.
LIMITATIONS	Automated scanners may produce false positives. Manual validation is recommended for all High/Critical findings before remediation. Server-side only vulnerabilities requiring authenticated access may not be fully detected.
AI ANALYSIS	Findings are analyzed by a large language model (LLM) for contextual risk assessment, remediation guidance, and business impact analysis. AI-generated content is cross-validated against raw scan data to prevent hallucination.

2 Executive Summary

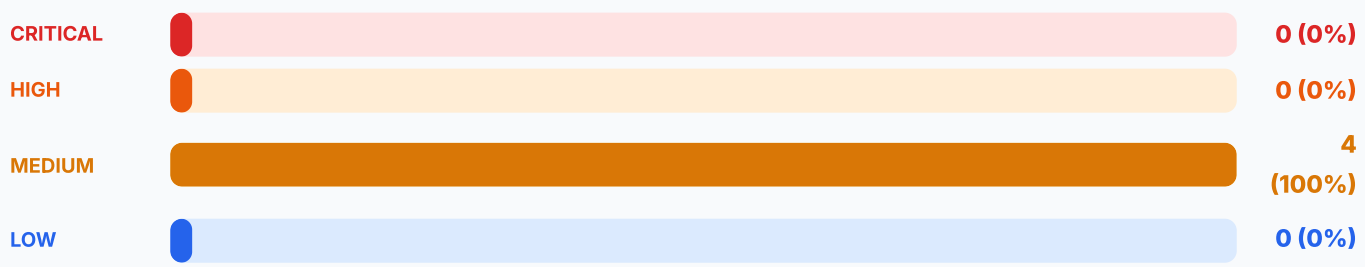
OVERALL SECURITY POSTURE

Good

Security Score: 80/100

0	0	4	0	4
CRITICAL	HIGH	MEDIUM	LOW	TOTAL

2.1 Severity Distribution



2.2 Assessment Overview

An automated security assessment was performed against http://zero.webappsecurity.com. The AI analysis engine encountered an error during report generation. The raw scan data is preserved below for manual review.

2.3 Security Posture Analysis

Due to a processing error (Request failed with status code 429), the AI-generated narrative could not be completed. Please review the raw findings data and technical evidence for manual analysis.

2.4 Technology Stack Analysis

Technology stack analysis unavailable due to AI processing error. Manual review of http://zero.webappsecurity.com recommended to identify server technologies, frameworks, and version-specific risks.

2.5 Key Observations

- 4 potential finding(s) detected by automated scanners
- AI analysis was unable to complete — manual review recommended
- Raw technical evidence has been preserved in the report appendix

2.6 Immediate Actions Required

#	ACTION	RATIONALE	TIMELINE	ASSIGN TO	REF
1	Review INFO DISCLOSURE HEADERS (Medium)	Automated scanner flagged this as Medium severity	ASAP	Security Team	V-001
2	Review MISSING SECURITY HEADERS (Medium)	Automated scanner flagged this as Medium severity	ASAP	Security Team	V-002
3	Review PERMISSIONS POLICY (Medium)	Automated scanner flagged this as Medium severity	ASAP	Security Team	V-003

3 Risk Overview

3.1 Risk Heatmap (Impact × Likelihood)

IMPACT ↓ / LIKELIHOOD →	HIGH	MEDIUM	LOW
Critical	—	—	—
High	—	—	—
Medium	—	V-001 V-002 V-003 V-004	—
Low	—	—	—

3.2 Priority Distribution

PRIORITY	DESCRIPTION	COUNT
P0	Immediate — Stop and fix	0
P1	High — Fix within current sprint	0
P2	Medium — Next maintenance cycle	4
P3	Low — Routine hardening	0

4 Detailed Security Findings

V-001 INFO DISCLOSURE HEADERS

MEDIUM | P2 | Risk: 35/100

RISK RATING

Assigned Medium based on automated scanner classification

AFFECTED COMPONENTS

- See technical evidence

TECHNICAL DESCRIPTION

Automated scanner detected potential INFO DISCLOSURE HEADERS. Evidence confidence: Medium. Manual validation required.

⚠️ ATTACK SCENARIO

AI analysis unavailable — refer to technical evidence for attack vector assessment.

💥 BUSINESS IMPACT

Unable to assess business impact automatically. Manual review by security team recommended.

COMPLIANCE IMPACT

Compliance impact assessment unavailable — requires manual review against applicable regulatory frameworks.

TECHNICAL EVIDENCE

ENDPOINT	METHOD	PARAMETER	PAYLOAD	OBSERVATION
http://zero.webappsecurity.com	GET	N/A	N/A	See raw scan output

✅ REMEDIATION

Recommendation: Validate finding manually before implementing remediation

```
Pending manual validation
```

⚡ **Quick Win:** Verify finding manually and apply vendor-recommended patches if applicable.

🔍 VERIFICATION

1. Validate the finding manually using a security testing tool
2. Attempt to reproduce the vulnerability with the provided evidence
3. If confirmed, apply the remediation steps

4. Rerun the automated scan to verify the fix

RESIDUAL RISK

Unknown — requires manual assessment after AI analysis is available.

V-002 MISSING SECURITY HEADERS

MEDIUM | P2 | Risk: 35/100

RISK RATING

Assigned Medium based on automated scanner classification

AFFECTED COMPONENTS

- See technical evidence

TECHNICAL DESCRIPTION

Automated scanner detected potential MISSING SECURITY HEADERS. Evidence confidence: Medium. Manual validation required.

ATTACK SCENARIO

AI analysis unavailable — refer to technical evidence for attack vector assessment.

BUSINESS IMPACT

Unable to assess business impact automatically. Manual review by security team recommended.

COMPLIANCE IMPACT

Compliance impact assessment unavailable — requires manual review against applicable regulatory frameworks.

TECHNICAL EVIDENCE

ENDPOINT	METHOD	PARAMETER	PAYLOAD	OBSERVATION
http://zero.webappsecurity.com	GET	N/A	N/A	See raw scan output

REMEDIATION

Recommendation: Validate finding manually before implementing remediation

```
Pending manual validation
```

Quick Win: Verify finding manually and apply vendor-recommended patches if applicable.

VERIFICATION

1. Validate the finding manually using a security testing tool

2. Attempt to reproduce the vulnerability with the provided evidence
3. If confirmed, apply the remediation steps
4. Rerun the automated scan to verify the fix

RESIDUAL RISK

Unknown — requires manual assessment after AI analysis is available.

V-003 PERMISSIONS POLICY

MEDIUM | P2 | Risk: 35/100

RISK RATING

Assigned Medium based on automated scanner classification

AFFECTED COMPONENTS

- `See technical evidence`

TECHNICAL DESCRIPTION

Automated scanner detected potential PERMISSIONS POLICY. Evidence confidence: Medium. Manual validation required.

ATTACK SCENARIO

AI analysis unavailable — refer to technical evidence for attack vector assessment.

BUSINESS IMPACT

Unable to assess business impact automatically. Manual review by security team recommended.

COMPLIANCE IMPACT

Compliance impact assessment unavailable — requires manual review against applicable regulatory frameworks.

TECHNICAL EVIDENCE

ENDPOINT	METHOD	PARAMETER	PAYLOAD	OBSERVATION
`http://zero.webappsecurity.com`	GET	`N/A`	`N/A`	See raw scan output

REMEDIATION

Recommendation: Validate finding manually before implementing remediation

```
Pending manual validation
```

Quick Win: Verify finding manually and apply vendor-recommended patches if applicable.

🔍 **VERIFICATION**

1. Validate the finding manually using a security testing tool
2. Attempt to reproduce the vulnerability with the provided evidence
3. If confirmed, apply the remediation steps
4. Rerun the automated scan to verify the fix

⚡ **RESIDUAL RISK**

Unknown — requires manual assessment after AI analysis is available.

V-004 TLS SECURITY CHECK

MEDIUM | P2 | Risk: 35/100

RISK RATING

Assigned Medium based on automated scanner classification

AFFECTED COMPONENTS

- `See technical evidence`

TECHNICAL DESCRIPTION

Automated scanner detected potential TLS SECURITY CHECK. Evidence confidence: Medium. Manual validation required.

⚠️ **ATTACK SCENARIO**

AI analysis unavailable — refer to technical evidence for attack vector assessment.

💥 **BUSINESS IMPACT**

Unable to assess business impact automatically. Manual review by security team recommended.

COMPLIANCE IMPACT

Compliance impact assessment unavailable — requires manual review against applicable regulatory frameworks.

TECHNICAL EVIDENCE

ENDPOINT	METHOD	PARAMETER	PAYLOAD	OBSERVATION
`http://zero.webappsecurity.com`	GET	`N/A`	`N/A`	See raw scan output

REMEDIATION

Recommendation: Validate finding manually before implementing remediation

```
Pending manual validation
```

Quick Win: Verify finding manually and apply vendor-recommended patches if applicable.

VERIFICATION

1. Validate the finding manually using a security testing tool
2. Attempt to reproduce the vulnerability with the provided evidence
3. If confirmed, apply the remediation steps
4. Rerun the automated scan to verify the fix

RESIDUAL RISK

Unknown — requires manual assessment after AI analysis is available.

5 Risk Register

ID	FINDING	SEVERITY	PRIORITY	RISK SCORE	STATUS
V-001	INFO DISCLOSURE HEADERS	MEDIUM	P2	35/100	Open
V-002	MISSING SECURITY HEADERS	MEDIUM	P2	35/100	Open
V-003	PERMISSIONS POLICY	MEDIUM	P2	35/100	Open
V-004	TLS SECURITY CHECK	MEDIUM	P2	35/100	Open

6 Strategic Recommendations

1. Manual Review

Recommendation: Conduct manual security testing to validate automated scan findings

Business Benefit: Reduces false positive remediation effort and confirms actual risk exposure

Estimated Effort: 2-4 hours per finding

🛠️ **Tools Required:** Burp Suite, OWASP ZAP, or manual browser testing

7 Security Program Improvements

PHASE	INITIATIVE	EXPECTED OUTCOME	EST. COST
Short-Term (0-3 months)	Validate all automated findings through manual penetration testing	Confirmed vulnerability inventory with accurate risk ratings	Internal resource allocation

📋 **Dependencies:** Security team availability and testing environment access

8 Overall Assessment Verdict

Good

Routine security hardening is sufficient. The application demonstrates a good security posture with only minor findings that can be addressed during regular maintenance.

This assessment is based on automated testing results and AI analysis. Manual validation is recommended for all High and Critical findings before concluding exploitability.

9 Disclaimer & Terms

Confidentiality Notice

This document contains confidential security assessment information. Distribution should be limited to authorized personnel with a legitimate need to know. Unauthorized disclosure may compromise the security posture of the assessed system.

Assessment Limitations

This assessment was conducted using automated scanning tools combined with AI-powered analysis. While comprehensive, automated testing cannot guarantee the detection of all vulnerabilities. This report does not constitute a guarantee of security. The following limitations apply:

- Testing was limited to externally-accessible attack surfaces (black-box methodology)
- Business logic vulnerabilities requiring authenticated access may not be detected
- AI-generated remediation guidance should be validated by qualified security professionals before implementation
- CVSS scores are estimated based on observed behavior and may differ from vendor-assigned scores
- The security landscape evolves continuously. New vulnerabilities may emerge after this assessment

Liability

VulnCraft and its AI systems provide this report “as-is” without warranty of any kind. The organization assumes all responsibility for implementing remediation measures and verifying their effectiveness. The assessors shall not be liable for any damages resulting from the use or inability to use the information contained herein.

Data Handling

Scan data and AI analysis results are processed in accordance with applicable data protection regulations. No customer data is exfiltrated during testing. All evidence collected is limited to server responses to security-focused requests.

Generated by **VulnCraft AI Security Assessment Platform**

Report generated on March 13, 2026 at 12:50 AM

© 2026 VulnCraft. All rights reserved.